

# Rapport de sécurité et conformité — ServiceNow AI Response Generator

**Version:** 1.0.0 **Date:** 2 mars 2026 **Auteur:** Yannick Pezeu **Destinataires:** Équipe Cybersécurité EPFL, Délégué à la Protection des Données (DPO)

## 1. Présentation du projet

### 1.1 Objectif

**ServiceNow AI Response Generator** est une extension pour navigateurs Chromium (Chrome, Edge, Opera, Brave, etc.) à usage interne qui assiste les agents du support de l'EPFL dans la rédaction de réponses aux tickets ServiceNow. L'extension injecte un bouton "Générer IA" dans l'interface de gestion des tickets, qui interroge un système de génération augmentée par récupération (RAG) hébergé à l'EPFL pour proposer un brouillon de réponse contextualisé.

**L'humain conserve le contrôle total :** la réponse générée est insérée comme brouillon dans le champ de texte et doit être relue et validée manuellement avant envoi.

**Les objectifs à long terme sont:**

- Démontrer la faisabilité et l'efficacité de ce type de réponse automatique pour assister le traitement des tickets Servicenow
- Motiver l'intégration de ce type de réponse automatique lors de la création des tickets servicenow.
- Permettre une alternative locale, souveraine et peu couteuse au service analogue proposé par ServiceNow.

### 1.2 Périmètre d'utilisation

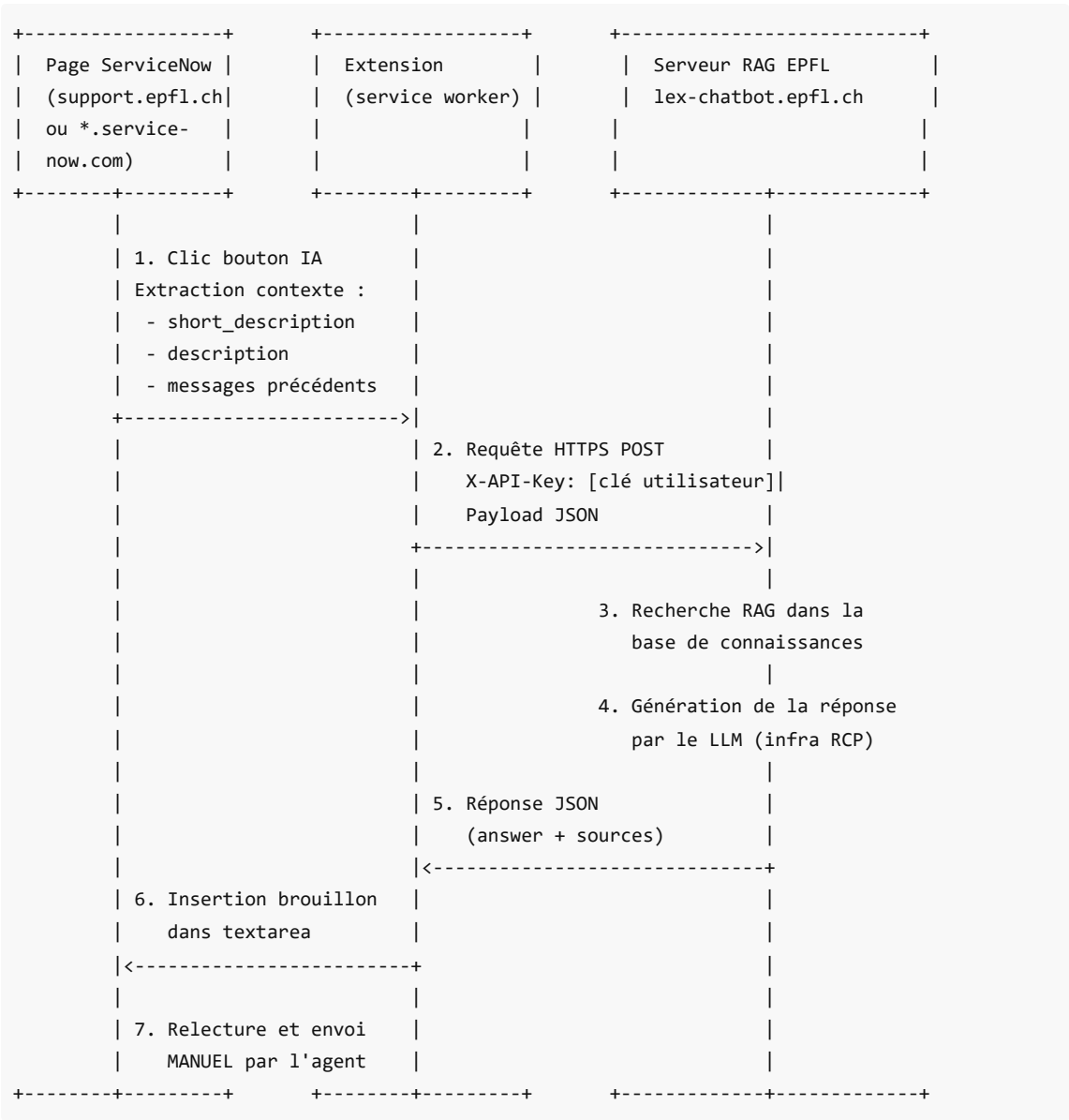
- Utilisateurs cibles :** Tous le personnel EPFL traitant courramment des tickets
- Distribution :** installation manuelle (mode développeur Chrome) dans un premier temps, avec publication sur le Chrome Web Store à terme (accès restreint au personnel EPFL via la visibilité "privée" du Chrome Web Store)
- Environnement :** navigateurs Chrome, Edge, Opera des postes de travail EPFL

## 2. Architecture technique

### 2.1 Composants de l'extension

| Fichier       | Rôle                                                                            | Contexte d'exécution            |
|---------------|---------------------------------------------------------------------------------|---------------------------------|
| manifest.json | Déclaration des permissions et portée                                           | Configuration Chromium          |
| content.js    | Injection du bouton IA dans le DOM ServiceNow, extraction du contexte du ticket | Content script (DOM ServiceNow) |
| inject.js     | Écriture de la réponse dans le textarea via le scope AngularJS                  | Main world (page ServiceNow)    |
| background.js | Proxy API — transmet les requêtes au serveur RAG EPFL                           | Service worker (isolé)          |
| popup.html/js | Interface de configuration (clé API, modèle, paramètres)                        | Popup de l'extension            |
| styles.css    | Style du bouton injecté                                                         | CSS injecté                     |

## 2.2 Flux de données



## 2.3 Données transmises au serveur RAG

Le payload JSON envoyé à l'API contient exclusivement :

| Champ             | Description                           | Contenu type                |
|-------------------|---------------------------------------|-----------------------------|
| short_description | Titre court du ticket                 | "Problème VPN campus"       |
| description       | Description détaillée du ticket       | Texte libre du demandeur    |
| previous_messages | Historique des échanges sur le ticket | Messages client/agent       |
| library           | Nom de la base de connaissances RAG   | "finance_embeddings" (fixe) |

|             |                                                   |                                        |
|-------------|---------------------------------------------------|----------------------------------------|
| model       | Identifiant du modèle LLM                         | Ex: "Qwen/Qwen3-VL-235B-A22B-Thinking" |
| index_key   | Clé d'accès à l'index de la base de connaissances | Clé configurée par l'utilisateur       |
| top_k       | Nombre de documents à récupérer                   | Entier (1-40, défaut 10)               |
| temperature | Paramètre de créativité du modèle                 | 0.3 (fixe)                             |
| rerank      | Activation du reranking des résultats             | Booléen                                |

**Données NON transmises** : identifiant de l'agent, credentials ServiceNow, cookies de session, numéro de ticket, informations système.

### 3. Permissions et surface d'attaque

#### 3.1 Permissions déclarées (Manifest V3)

| Permission | Justification                                                |
|------------|--------------------------------------------------------------|
| activeTab  | Accès au contenu de l'onglet actif uniquement                |
| storage    | Stockage local des préférences (clé API, modèle, paramètres) |

#### 3.2 Host permissions

| Domaine                       | Justification                                   |
|-------------------------------|-------------------------------------------------|
| https://lex-chatbot.epfl.ch/* | Unique endpoint API contacté (serveur RAG EPFL) |

#### 3.3 Sites d'injection du content script

| Pattern                 | Justification                             |
|-------------------------|-------------------------------------------|
| *://*.service-now.com/* | Pages ServiceNow (domaine générique SaaS) |
| *://support.epfl.ch/*   | Instance ServiceNow spécifique EPFL       |

#### 3.4 Évaluation de la surface d'attaque

- **Permissions minimales** : l'extension ne demande pas `tabs` , `webRequest` , `cookies` , `history` ni aucune permission sensible. Elle n'a pas accès à l'ensemble de la navigation.
- **Aucune communication externe** : le seul serveur contacté est `lex-chatbot.epfl.ch` , hébergé et administré par l'EPFL.
- **Pas de code distant** : aucun script externe n'est chargé. Tout le code est inclus dans l'extension.
- **Manifest V3** : utilise l'architecture d'extension la plus récente et la plus restrictive des navigateurs Chromium (service worker isolé, pas de `eval()` , CSP stricte).

### 4. Stockage des données

#### 4.1 Données stockées localement

| Donnée          | Mécanisme                         | Sensibilité | Remarques                                                 |
|-----------------|-----------------------------------|-------------|-----------------------------------------------------------|
| Clé API         | <code>chrome.storage.local</code> | Élevée      | Voir section 4.2                                          |
| Index Key       | <code>chrome.storage.local</code> | Élevée      | Clé d'accès à l'index RAG, même traitement que la clé API |
| Modèle choisi   | <code>chrome.storage.local</code> | Faible      | Identifiant de modèle public                              |
| Top K           | <code>chrome.storage.local</code> | Faible      | Paramètre numérique                                       |
| Rerank (on/off) | <code>chrome.storage.local</code> | Faible      | Booléen                                                   |

#### 4.2 Gestion de la clé API

- La clé API est stockée via `chrome.storage.local`, qui est **isolée par extension** et inaccessible aux sites web ou autres extensions.
- Le stockage n'est **pas chiffré au repos** par Chrome au-delà du chiffrement du profil utilisateur. Ce comportement est identique à celui des gestionnaires de mots de passe intégrés aux navigateurs.
- La clé est transmise uniquement en en-tête HTTP ( `X-API-Key` ) vers `lex-chatbot.epfl.ch` via **HTTPS**.
- **Aucune clé n'est codée en dur** dans le code source.

#### 4.3 Données NON stockées

- Le contenu des tickets (descriptions, messages) **n'est jamais persisté** localement. Il est extrait du DOM à chaque clic et transmis en mémoire uniquement.
- Les réponses générées ne sont pas mises en cache.

### 5. Analyse de conformité — Protection des données

#### 5.1 Données personnelles potentiellement traitées

Les tickets ServiceNow peuvent contenir des données personnelles :

| Catégorie                       | Exemples                                           | Probabilité |
|---------------------------------|----------------------------------------------------|-------------|
| Identifiants                    | Noms, prénoms, adresses email EPFL, numéros SCIPER | Élevée      |
| Données techniques              | Adresses IP, noms de machines, identifiants réseau | Élevée      |
| Données organisationnelles      | Unité, fonction, laboratoire                       | Élevée      |
| Données sensibles (art. 5 nLPD) | Données de santé, opinions                         | Élevée      |

#### 5.2 Base légale du traitement

Le traitement s'inscrit dans le cadre de la **mission de support IT de l'EPFL** (intérêt public, art. 35 nLPD pour les organes fédéraux). L'extension est un outil d'aide à la rédaction qui ne modifie pas la finalité du traitement existant des tickets.

#### 5.3 Destinataire des données

| Destinataire | Données reçues | Localisation |
|--------------|----------------|--------------|
|--------------|----------------|--------------|

|                           |                                             |                     |
|---------------------------|---------------------------------------------|---------------------|
| Serveur RAG EPFL          | Contexte du ticket (description + messages) | Infrastructure EPFL |
| Fournisseur du modèle LLM | RCP                                         | Infrastructure EPFL |

**Point d'attention** : le serveur `lex-chatbot.epfl.ch` exécute les modèles LLM localement sur l'infrastructure RCP de l'EPFL. Il ne transmet pas les données à un fournisseur cloud externe.

## 5.4 Principes de protection des données

| Principe             | Conformité  | Remarques                                                                                                                                                                                                            |
|----------------------|-------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Finalité             | Conforme    | Aide à la rédaction de réponses support uniquement                                                                                                                                                                   |
| Proportionnalité     | Conforme    | Seuls les champs nécessaires à la génération sont transmis                                                                                                                                                           |
| Minimisation         | À améliorer | Possibilité d'anonymiser les données avant envoi (voir sec. 7). Ajout d'une couche de complexité jugée inutile dans la mesure où le traitement des données ne quitte pas l'epfl et n'est pas stockée dans le système |
| Transparence         | À compléter | Les demandeurs de tickets doivent-ils être informés de l'usage d'IA ?                                                                                                                                                |
| Sécurité             | Conforme    | HTTPS, permissions minimales, pas de stockage de contenu                                                                                                                                                             |
| Conservation limitée | Conforme    | Aucune donnée de ticket persistée                                                                                                                                                                                    |

## 6. Risques identifiés et mesures de mitigation

### 6.1 Matrice des risques

| # | Risque                                          | Impact | Probabilité | Mitigation                                                                                                                                                                                                                                                                                                               |
|---|-------------------------------------------------|--------|-------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| 1 | Fuite de la clé API                             | Moyen  | Faible      | Stockage isolé par le navigateur, transmission HTTPS uniquement                                                                                                                                                                                                                                                          |
| 2 | Données personnelles dans le payload API        | Élevé  | Élevée      | Aucune donnée personnelle n'est stockée après traitement. Ni par l'extension, ni par l'api de réponse ni par RCP pour le LLM. Voir evaluation de la sécurité du serveur proposant les réponses:<br><a href="https://github.com/YannickPezou/Hierarchical_search">https://github.com/YannickPezou/Hierarchical_search</a> |
| 3 | Injection de contenu malveillant via réponse IA | Moyen  | Faible      | La réponse est insérée en texte brut (pas de HTML interprété)                                                                                                                                                                                                                                                            |
| 4 | Réponse IA incorrecte envoyée au client         | Moyen  | Moyenne     | Relecture obligatoire par l'agent avant envoi                                                                                                                                                                                                                                                                            |

|   |                                               |        |             |                                                                          |
|---|-----------------------------------------------|--------|-------------|--------------------------------------------------------------------------|
| 5 | Extension compromise (supply chain)           | Élevé  | Très faible | Code source auditable, pas de dépendances externes, distribution interne |
| 6 | Modification non autorisée de l'UI ServiceNow | Faible | Très faible | Modifications côté client uniquement, aucun impact serveur               |

### 6.2 Mesures de sécurité en place

1. **Isolation du service worker** : les appels API sont effectués dans le service worker du navigateur, isolé du contexte de la page web.
2. **HTTPS exclusif** : toute communication avec le serveur RAG utilise HTTPS.
3. **Permissions minimales** : seules `activeTab` et `storage` sont demandées — aucun accès étendu.
4. **Aucun code distant** : pas de CDN, pas de script externe, pas de `eval()` .
5. **Manifest V3** : architecture Chromium la plus restrictive disponible.
6. **Aucun stockage de contenu** : les données de tickets ne sont jamais persistées.
7. **Timeout des requêtes** : les appels API sont annulés après 120 secondes.

## 7. Recommandations

### 7.1 À court terme (avant déploiement)

| #  | Recommandation                                                                      | Priorité |
|----|-------------------------------------------------------------------------------------|----------|
| R1 | Informar les agents support de la nature de l'outil et de la nécessité de relecture | Haute    |

### 7.2 À moyen terme (améliorations)

| #  | Recommandation                                                                                          | Priorité |
|----|---------------------------------------------------------------------------------------------------------|----------|
| R2 | Ajouter une mention dans les réponses envoyées aux clients indiquant l'assistance par IA (transparence) | Moyenne  |
| R3 | Mettre en place un journal d'utilisation local (nombre d'appels, sans contenu) pour audit               | Faible   |
| R4 | Envisager une intégration via l'API officielle ServiceNow plutôt qu'une injection DOM                   | Faible   |

## 8. Conclusion

L'extension ServiceNow AI Response Generator présente un **profil de risque faible** du point de vue de la sécurité informatique : permissions minimales, aucune dépendance externe, code auditable, et communication exclusivement avec un serveur EPFL.

Le **principal point d'attention** concerne la protection des données : les tickets ServiceNow contiennent potentiellement des données personnelles qui sont transmises au serveur RAG. La conformité complète est assurée par le traitement LLM qui reste sur l'infrastructure EPFL sans logs. Pour une évaluation de la sécurité des données dans le serveur générant les réponses, veuillez vous référer au document de sécurité du serveur.

L'outil ne remplace pas le jugement humain — il propose un brouillon que l'agent revoit et valide avant tout envoi.

## Annexe A — Exemple de payload API

```
{
  "description": "Je n'arrive pas à me connecter au VPN depuis mon domicile.",
  "short_description": "Problème connexion VPN",
  "previous_messages": [
    { "sender": "client", "content": "Le VPN ne fonctionne plus depuis ce matin." },
    { "sender": "agent_support", "content": "Pouvez-vous préciser le message d'erreur ?" }
  ],
  "library": "finance_embeddings",
  "model": "Qwen/Qwen3-VL-235B-A22B-Thinking",
  "index_key": "[clé d'accès à l'index]",
  "top_k": 10,
  "temperature": 0.3,
  "rerank": true
}
```

## Annexe B — Permissions Chromium détaillées

```
{
  "permissions": ["activeTab", "storage"],
  "host_permissions": ["https://lex-chatbot.epfl.ch/*"],
  "content_scripts.matches": [
    "*/**/*.service-now.com/*",
    "*/**/support.epfl.ch/*"
  ]
}
```